
UFW and Nmap

Build I.T. Club

About Firewalls

- At a most basic form, exist on the perimeter of a host or network
- Set of rules to define what ports, protocols, and actions
- Choose what is exposed to the network
 - Deny access to weak or unnecessary network protocols (especially remote access)
- UFW is a simpler firewall compared iptables (or nftables)
 - Abstracts the configuration into simple rules, still uses iptables or nftables as backend
- Raspberry Pi does not come with a firewall by default

About Nmap

- Stands for network mappers, network scanner
- Discover hosts, open ports, and services
- Can guess operating system based on fingerprint of the system
- Multiple different flags based on what you want to do
 - Default is -sS, fastest way to scan as it does not complete TCP connection
 - -sU, scan for ports open to UDP connections
 - -p port(s) or port name
 - -O, tries to guess what OS is running
 - -Pn, skips the ping check that tests if host is online/reachable

Install packages

- `sudo apt install vim`
- `sudo apt install ufw`
- `sudo apt install nmap`
- `sudo apt install nginx`
- `sudo apt install wireshark`

Verify Connection

- Try ssh to another person's Pi with `ssh <username>@<ip>`
- Try to access another person's default nginx website by typing ip into browser

Run Nmap

- Run nmap against another pi: `sudo nmap <ip>`
- Should see something like port 22, 80, 111 are open and have a service
 - Just because nmap reports the other ports as closed does not mean that it is actually closed
 - If a port does not have a service running that responds then by default reported as closed
- Take note that port 22 is ssh and port 80 is http
 - Ports 0-1023 are well known ports, used by system services
 - There are other registered ports such that port 3389 for RDP

Viewing Nmap

- Run `sudo wireshark`
- Select all interface
- In the top search bar like interface filter the packets with `ip.src==<ip>` where `<ip>` is the ip of the other person's Pi
 - This filters packets so only packets from the specified ip are shown
- Run `sudo nmap <ip>`
 - View as the packets come in on wireshark
 - If you click on the packets you can see some of the ports it tried to detect services on

UFW

- Run `sudo ufw status`
 - This shows the current status included what rules are applied, should say inactive
- Run `sudo allow 22`
 - This allows connections to port 22 (ssh)
- Run `sudo ufw enable` then `ufw status`
 - Should now show that any connection to port 22 is allowed
- Run `nmap` again, should show only port 22 if open
- Try `nmap -su <ip>` this tries UDP
 - Note that it shows that ufw still allows in a UDP connection on port 22

Further UFW configurations

- Restricting ssh to tcp only
 - SSH runs on tcp, leaving udp exposed is unnecessary
- Run `sudo ufw delete allow 22`
 - Note that another way would be to do `ufw status numbered` then delete by rule number
- Run `sudo ufw allow ssh/tcp`
 - Note that can use protocol name and /tcp or /udp to specify protocol
- Run `sudo ufw reload`
- Test `nmap -su <ip>` again

Further UFW configurations

- You can further specify which ips can access a port
- Run `sudo ufw allow from <ip> to any port 80 proto tcp`
- Run `sudo ufw reload`
 - The Pi with the ip will be able to access the website and nmap will report the port as up
 - Any other device with a different ip will be blocked

Beyond UFW and Nmap

- Firewalls
 - iptables/nftables: more complex but more options for configuration
 - `-A INPUT -p tcp -m state --state NEW -m tcp --dport 22 -j ACCEPT`
 - firewalld: default on RHEL based systems, zone based
- Vulnerability scanners
 - Go beyond detecting services, tries to determine service version and configuration
 - Check against known CVEs and exploits